Pericope ERM - Complete Feature Reference Manual

Platform: Pericope Enterprise Risk Management & GRC Suite

Authors: Srivatsan B (1AT23CG104), Raja Vishnu (1AT23CG080), Rithvik R (1AT23CG084), Niranthar M Javagal (1AT23CG071)

Institution: Dept. of Computer Science & Engineering, Atria Institute of Technology

Version: 3.5 (Complete Feature Edition)

1. Platform Overview & Core Architecture

Pericope ERM is an enterprise Governance, Risk, and Compliance (GRC) platform built on a three-tier, resilience-first architecture over an **Oracle Autonomous Database** schema. It digitizes the entire risk lifecycle, replacing disconnected Excel spreadsheets with an automated, auditable, and mathematically quantified system of record.

2. Executive Dashboard (/dashboard)

The Executive Dashboard serves as the central command cockpit for risk leaders and executive management:

- **4 Operational KPI Panels:**
  - **Active Risks:** Real-time active risk count, highlighting critical severity items.
  - **Single Loss Expectancy (SLE):** Aggregate monetary exposure ($SLE = S x $10,000).
  - **Control Coverage:** Percentage of cataloged risks mitigated by active internal controls.
  - **Assessment Completion:** Proportion of active departmental RCSA cycles completed and attested.
- **Trailing Risk Velocity Chart:** Interactive 6-month area chart modeling risk registration and closure trends.
- **Risk Allocation by Department:** Direct percentage breakdown of risk concentration across IT, Finance, Procurement, Operations, and Legal.
- **Recent Risk Entries Ledger:** High-density data table displaying recently cataloged risks, department scopes, SLE valuations, and direct review links.

3. RCSA Lifecycle Workflow (4-Stage Stepper)

Pericope ERM guides risk teams through a structured 4-stage assessment workflow:

Stage 1: Assessment Setup & Provisioning (/rcsa/provisioning)

- **Cycle Provisioning:** Define quarterly and annual assessment cycles by business unit (e.g. `RCSA-FIN-2026-001` for Finance & Treasury).
- **Metadata Parameters:** Assign risk champions, estimated start/end dates, departmental scopes, and lifecycle statuses (Draft, In Progress, Completed).
- **Industry Starter Packs:** 1-Click seeding of pre-configured assessment templates for **Fintech & Banking**, **Cloud/SaaS Security**, and **Healthcare (HIPAA)**.
- **Assessment Details Drilldown (/rcsa/provisioning/[id]):** Directly opens the dedicated workspace for a specific assessment, displaying all connected risks and control mapping actions.

Stage 2: Risk Identification & Cataloging (/rcsa/identification)

- **Risk Scenario Registration:** Form modal to capture detailed risk statements, categories, departments, Likelihood (1-5), and Impact (1-5).
- **Automated Single Loss Expectancy:** Computes SLE = L x I x $10,000 in real time upon score entry.
- **Bulk Spreadsheet (CSV) Importer:** Native CSV file parser allowing risk teams to drag-and-drop existing Excel risk registers, preview parsed rows, and import them in bulk with instant database validation.
- **Sample CSV Template Generator:** 1-Click download of `pericope_risk_register_template.csv`.

Stage 3: Mitigation & Control Mapping (/rcsa/mitigation)

- **Departmental Mitigation Overview:** Collapsible department accordion rows displaying control counts and exposure totals.
- **Risk Mitigation Profile (/rcsa/mitigation/[id]):** Deep-dive workspace for a single risk showing inherent vs residual score, risk reduction percentage, mapped controls, and remediation action plans.
- **Applied Controls Mapper (/rcsa/provisioning/[id]/controls/[riskId]):** Tag controls to a specific risk, configure testing frequency (Daily, Weekly, Monthly, Continuous), and set Design (1-5) and Operating (1-5) scores.

Stage 4: Continuous Risk Monitoring (/rcsa/monitoring)

- **Remediation Action Tracking:** Track milestone deadlines, assigned owners, and percentage completion.
- **Lifecycle Sign-off:** Maker-checker attestation to mark assessment cycles as validated and completed.

4. Advanced Risk Analytics & 5x5 Heatmaps (/heatmaps)

- **Bi-Axial Coordinate Grid:**
- **Vertical Y-Axis (Likelihood):** `5 – Almost Certain (>80%)`, `4 – Likely (50–80%)`, `3 – Possible (20–50%)`, `2 – Unlikely (5–20%)`, `1 – Rare (<5%)`.
- **Horizontal X-Axis (Impact):** `1 – Insignificant (<$25K)`, `2 – Minor ($25K–$100K)`, `3 – Moderate ($100K–$250K)`, `4 – Major ($250K–$1M)`, `5 – Severe (>$1M)`.
- **Multi-View Modes:**
- **Inherent Exposure:** Pre-control gross risk distribution across the 5x5 matrix.
- **Residual Risk:** Post-control stepped-down risk distribution showing how controls push risks into the acceptable green zone.
- **Risk Velocity:** Trailing trajectory and emerging threats.
- **Interactive Cell Inspection:** Clicking any active cell with numbers opens an inspection dialog listing the exact risk statements, owners, and individual SLE valuations.

5. Key Risk Indicators (KRI) & Live Telemetry (/kri)

- **Continuous Telemetry Tracking:** Automated threshold monitoring across operational, cyber, financial, and people metrics.
- **Threshold Color Bands:**
- **Green (Normal):** Below amber boundary.
- **Amber (Warning):** Approaching risk tolerance limit.
- **Red (Critical Breach):** Tolerance breached; immediate escalation triggered.
- **Live Reading Simulator & Updater:** Users can click the update icon on any KRI card to log a new measurement (e.g. entering `14.5` hrs for outage hours) and observe the card transition immediately to Red, updating trend lines and logging an audit event.
- **Directional Logic:** Supports both `higher-worse` (e.g. outage hours, CVE count) and `lower-worse` (e.g. cash runway, operating margin) metrics.

6. Governance, Controls & Maker-Checker Workflows

Control Library & Testing (/control-library)

- **Central Control Register:** Catalog preventive, detective, corrective, and compensating controls.
- **Multi-Framework Tagging:** Tag controls against **ISO/IEC 27001**, **SOX 404**, **GDPR**, **SOC 2**, and **NIST SP 800-53**.
- **Effectiveness Scoring:** Record Design Effectiveness (1-5) and Operating Effectiveness (1-5) testing results.

Risk Appetite & Tolerance Framework (/risk-appetite)

- **Appetite Statements:** Formal qualitative posture (Averse, Cautious, Open, Hungry) and quantitative thresholds by domain (Strategic, Financial, Operational, Compliance, IT & Cyber).
- **Appetite vs Exposure Gauges:** Real-time visualization comparing active portfolio exposure against Board-approved tolerance limits.

Maker-Checker Approval Engine (/workflow)

- **Segregation of Duties (SoD):** Multi-step approval chains where assessors submit requests and risk managers/administrators review, approve, or reject with documented comments.
- **Supported Approval Types:** Risk Assessments, Mitigation Plans, Control Changes, Policy Updates, and Formal Risk Acceptances.

Policy Management Center (/policy)

- **Policy Versioning & Ownership:** Central register of corporate policies, version numbers, effective dates, and review cadences.
- **Acknowledgment Tracking:** Tracks employee acknowledgment compliance percentages.

7. Enterprise Risk & Operational Resilience

Third-Party Risk Management (TPRM) (/vendor-risk)

- **Tiered Vendor Portfolio:** Categorize third-party suppliers into Critical, High, Medium, and Low risk tiers.
- **Contract & Assessment Tracking:** Track contract values, risk scores (1-100), due diligence questionnaire (DDQ) completion, and upcoming audit reviews.

Incident & Loss Event Tracker (/incidents)

- **Loss Event Logging:** Log operational failures, cyber incidents, and vendor breaches.
- **Root-Cause & Corrective Action Tracking:** Document root-cause investigations, assigned remediation owners, and Mean Time to Resolve (MTTR).

Business Continuity Planning (BCP / DRP) (/bcp)

- **Disaster Recovery Metrics:** Define Recovery Time Objectives (RTO in hours) and Recovery Point Objectives (RPO in hours) for critical business processes.
- **Testing Cadence:** Monitor test schedules, overdue reviews, and operational failover readiness.

Scenario Analysis & FAIR Monte Carlo Stress Lab (/scenario)

- **Forward-Looking Shock Simulation:** Model macro and operational shocks (e.g. 20% currency devaluation, cloud region outage, major customer loss).
- **Probabilistic Quantification:** Execute 10,000 Monte Carlo iterations modeling Poisson event frequency and Lognormal loss magnitudes to compute **Annualized Loss Expectancy (ALE)** and **95% Value at Risk (VaR 95)**.

8. Audit, Administration & Security (RBAC)

Immutable Audit Trail (SOX 404) (/audit-trail)

- **Complete Event Logging:** Captures all creates, updates, deletes, approvals, logins, role changes, and exports with user attribution (`actor_id`, `actor_name`, `actor_role`).
- **Filtering & Export:** Filter by date range, action type, or search term, with 1-click **Export to CSV**.
- **Database Triggers:** Backed by autonomous transaction triggers in Oracle SQL (`fix_pericope_erm.sql`) ensuring audit entries cannot be tampered with or aborted.

User Management & Role-Based Access Control (/users)

- **5 Standard Enterprise Roles:**
- **Administrator:** Full platform control, user management, and system parameters.
- **Risk Manager:** RCSA approvals, control testing validation, and KRI threshold configuration.
- **Assessor:** Risk identification, inherent and residual assessment scoring (no destructive delete).
- **Auditor:** Read-only access to all registers, workpapers, and the immutable audit log.
- **Viewer:** Read-only C-suite access to executive dashboards, heatmaps, and reports.
- **Inline Role Assignment:** Administrators can change roles, activate/deactivate accounts, or provision new users.

System Setup & Security Parameters (/settings)

- Organization profile settings, reporting currency selection, notification routing, session timeout, and data retention rules (e.g. 7-year SOX audit log retention).

9. Reporting & Board Risk Deliverables (/reports)

Selecting any report from the left catalog renders a distinct, data-backed deliverable with clean `@media print` formatting:

- **RPT-001: Executive Board Risk Committee Pack:** Gross SLE, critical risk table, KRI threshold scorecard, and CRO sign-off.
- **RPT-002: RCSA Assessment Lifecycle Summary:** Department-wise cycle progression (Setup → Identify → Controls → Monitor).
- **RPT-003: SOX Section 404 Control Test Workpapers:** Internal Controls Over Financial Reporting (ICFR) testing matrix with design/operating scores.
- **RPT-004: Immutable Audit Trail Ledger (SOX):** Complete chronological event log with user attribution.
- **RPT-005: Key Risk Indicator (KRI) Threshold Register:** Comprehensive telemetry register showing green/amber/red boundaries and current values.
- **RPT-006: Control Effectiveness & Residual Risk Report:** Inherent to residual risk step-down matrix (L x I → L_res x I_res).
- **RPT-007: ISO/IEC 27001 Security Evidence Pack:** Annex A security controls implementation matrix and CISO attestation.
- **RPT-008: Third-Party Vendor Risk Assessment (TPRM):** Vendor criticality tier breakdown, contract spend, and review dates.
- **1-Click Print / Save as PDF:** Custom print stylesheets strip all browser UI, sidebars, and buttons, rendering only the clean, full-width executive report.

10. Data Ingestion & Migration Tools

- **CSV Bulk Risk Importer:** Accessible in `/rcsa/identification`, allows uploading external spreadsheets with live row preview and validation.
- **Sample CSV Template Exporter:** Pre-mapped spreadsheet format for rapid risk migration.
- **Demo Starter Packs:** One-click pre-population of Fintech, SaaS, or Healthcare assessment cycles in `/rcsa/provisioning`.
- **Fast Persona Switcher:** Top navbar dropdown allowing live role switching without logging out.
- **Quick Tools Drawer:** Floating reviewer toolkit with demo reset, feedback logger, and print triggers.

11. Backend & Database Architecture

- **Node.js BFF API (`server.js`):** Bounded 8-second circuit-breaker timeout, in-memory shadow store fallback, uppercase Oracle casing (`toOracleCase`), and regex-based input sanitization.
- **Oracle Autonomous Database:** 48 relational entities partitionable into core `PER_` *and telemetry* `ERM_` schemas.
- **Autonomous Audit Triggers (`fix_pericope_erm.sql`):** Uses `PRAGMA AUTONOMOUS_TRANSACTION` to ensure audit writes never abort primary business DML operations.
- **QA Test Suite (`qa_test_suite.mjs`):** 12 automated unit and integration tests verifying scoring bounds, Single Loss Expectancy, multi-factor residual calculations, FAIR Monte Carlo math, and CRUD engines.